



Samsung PlayGalaxy Link on PC

Connect to your PC over WiFi or mobile data and stream games on to your Samsung device. <https://dgit.in/dec19-47>



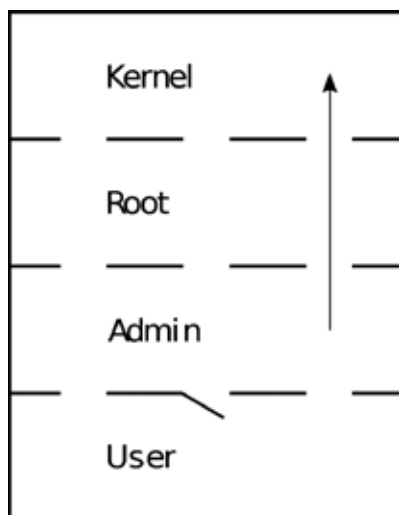
Samsung ditch Qualcomm scanner?

Reports suggest that Samsung may ditch Qualcomm's ultrasonic fingerprint scanner for next year. <https://dgit.in/dec19-48>

have kept passwords/credentials in easily breakable encryptions or even in plain-text, hoping no one will look there! This sometimes gives the attacker an easy way in. Having guessable passwords for master passwords of password managers can prove harmful too. To this, add the human nature of reusing passwords and you give attackers a one up on your security.

• Custom Exploits:

Services, no matter how robust the developer thinks it is, exploits may arise due to a lack of proper coding practices. While doing KryptOS, the privilege



escalation was the hardest we have encountered till that point (after all the machine was rated insane), because a custom exploit was required. One of the service's python code was retrievable and it was using a pseudo-random number generator (PRNG) to authenticate itself to another service. Now this PRNG was broken as in no matter how many random numbers you generate, only around 100 were unique in them which allowed a brute force attack. These custom exploits may result in direct privilege access or may provide enough to move ahead.

MS Windows Privilege Escalation Attacks:

The second major OS used by the server/websites on the internet is the ever-favorite desktop operating system, MS

Windows. Due to less customisability and its closed-sourced nature, Windows privilege escalation is not as popular as Unix/Linux privilege escalation but nonetheless, there are numerous ways to get administrator access (notice how it's 'administrator' for Windows while 'root' for Unix/Linux systems).

• DLL Hijacking:

After a long day of work, you settle down to enjoy an hour or two of your favorite RPG. But uh oh! What's that? The infamous "xxxxx.dll not found" error pops up. You wouldn't have thought in your wildest dreams that these files could be crafted to take down your system. Whenever a Windows application is executed, it looks for dynamic linked libraries (DLLs) which are loaded during runtime. Now if a DLL is missing the application will give an error. This gives the attacker an opportunity to inject malicious and specially crafted DLLs which the application might use thinking it's the real deal. This leads to escalated privileges.

• Insecure Credentials:

This category is common to both Linux/Unix and Windows, which is understandable because after all developers think alike, sometimes in a bad way. Once we encountered a machine using a version of mRemoteNG, a famous remote connection manager, which stored the master password in a hash form, which was breakable (there is a Metasploit module and numerous scripts available online). Another way to gain credentials is from unsecured backups. For example, the SAM file in Windows is a database file that stores user passwords, is present in C:\Windows\System32\config folder but is not accessible when the OS is running. But if this file is extracted through a backup, that can prove to be hazardous. Some processes may dump clear-text passwords when their process are analyzed. One good tool to do this is procdump.

• Popular Vulnerabilities:

New zero-day vulnerabilities are being discovered daily and lots of them allow

local/remote privilege escalation. The .NET Framework local privilege escalation vulnerability (<https://dgit.in/dot-netvuln>) which was recently discovered in September 2019 is one of them or the more popular group of vulnerabilities like EternalBlue/EternalRocks/Blue-Keep etc, are very harmful unless they are patched.

Brief about MacOS privilege escalation attacks:

MacOS is the host OS of very few computers running on the Internet but still widely used as a personal computer. Some of the exploits that exist are mainly for older versions, like the "Windows Server" component (<https://dgit.in/macwinserv>) which had a high severity or the Kernel-LPE vulnerability present in the <18.7.0 versions (<https://dgit.in/1870>). Most of these are not useful in the actual environment and real-time pen-testing. In fact, one researcher going by the name of "Siguza" released details of one such attack back in 2018 and here comes the fun part, the vulnerability was present in the OS since 2002! That's huge! But guess Apple got lucky since a good guy found the exploit before the bad guys.

• Local System Enumeration:

Usually, to figure out what kind of approach or which attack vector is the most optimal to perform, initial system enumeration performs a crucial role. Knowledge of users, groups, file permissions, and other information is very important. This step is mostly automated using numerous OS enumeration scripts. There are a lot of scripts, here are some of the most famous and most used one:

- Unix/Linux:
 - enum4linux (<https://dgit.in/enum4linux>)
 - linux-smart-enumeration (<https://dgit.in/smartenum>)
 - LinEnum (<https://dgit.in/linenum>)
 - linuxprivchecker (<https://dgit.in/linuxprivcheck>)